machine learning & knowledge extraction

MDPI

Systematic Review

AI-Powered Vulnerability Detection and Patch Management in Cybersecurity: A Systematic Review of Techniques, Challenges, and Emerging Trends

Malek Malkawi [1,*] and Reda Alhajj [1,2,3]

[1] Department of Computer Engineering, Istanbul Medipol University, Istanbul 34810, Turkey; alhajj@ucalgary.ca
[2] Department of Computer Science, University of Calgary, Calgary, AB T2N 1N4, Canada
[3] Department of Health Informatics, University of Southern Denmark, 5230 Odense, Denmark
* Correspondence: malek.malkawi@medipol.edu.tr

Abstract

With the increasing complexity of cyber threats and the inefficiency of traditional vulnerability management, artificial intelligence has been increasingly integrated into cybersecurity. This review provides a comprehensive evaluation of AI-powered strategies including machine learning, deep learning, and large language models for identifying cybersecurity vulnerabilities and supporting automated patching. In this review, we conducted a synthesis and appraisal of 29 peer-reviewed studies published between 2019 and 2024. Our results indicate that AI methods substantially improve the precision of detection, scalability, and response speed compared with human-driven and rule-based approaches. We detail the transition from conventional ML categorization to using deep learning for source code analysis and dynamic network detection. Moreover, we identify advanced mitigation strategies such as AI-powered prioritization, neuro-symbolic AI, deep reinforcement learning and the generative abilities of LLMs which are used for automated patch suggestions. To strengthen methodological rigor, this review followed a registered protocol and PRISMA-based study selection, and it reports reproducible database searches (exact queries and search dates) and transparent screening decisions. We additionally assessed the quality and risk of bias of included studies using criteria tailored to AI-driven vulnerability research (dataset transparency, leakage control, evaluation rigor, reproducibility, and external validation), and we used these quality results to contextualize the synthesis. Our critical evaluation indicates that this area remains at an early stage and is characterized by significant gaps. The absence of standard benchmarks, limited generalizability of the models to various domains, and lack of adversarial testing are the obstacles that prevent adoption of these methods in real-world scenarios. Furthermore, the research suggests that the black-box nature of most models poses a serious problem in terms of trust. Thus, XAI is quite pertinent in this context. This paper serves as a thorough guide for the evolution of AI-driven vulnerability management and indicates that next-generation AI systems should not only be more accurate but also transparent, robust, and generalizable.

Keywords: systematic review; cybersecurity; artificial intelligence; vulnerability detection; vulnerability prioritization; large language models; deep reinforcement learning; explainable AI

Check for updates

Academic Editor: Simon Tjoa

Received: 7 December 2025
Revised: 1 January 2026
Accepted: 8 January 2026
Published: 15 January 2026

Copyright: © 2026 by the authors. Licensee MDPI, Basel, Switzerland. This article is an open access article distributed under the terms and conditions of the Creative Commons Attribution (CC BY) license.

1. Introduction

Digital technologies have reshaped modern life—from healthcare to critical infrastructure [1]. This transformation, driven by the Internet of Things (IoT), cloud computing, and increasingly complex software supply chains, has enabled major innovation while substantially expanding the attack surface [2,3]. As organizations become more interconnected, vulnerabilities pose a growing challenge for enterprise risk management [4,5]. Cyber threats are difficult to anticipate and prevent, and their frequency and sophistication continue to rise; the cost of cybercrime is expected to reach USD 10.5 trillion annually in 2025 [6].

A central challenge in this expanded threat landscape is the limited scalability and responsiveness of traditional vulnerability management. Approaches such as manual code review, signature-based detection, and rule-based intrusion detection systems (IDSs) are increasingly outpaced by sophisticated attacks [7,8]. These methods are largely reactive, and they face several well-established limitations:

- Scalability: with growing asset inventories, manual and human-centric analysis quickly reaches its scalability limits [9–11].
- Speed: the interval between vulnerability disclosure and exploitation continues to shrink; manual patch deployment and prioritization are often too slow, leaving systems exposed for weeks or months [12–14].
- Complexity: signature- and rule-based systems are inherently limited when facing new, polymorphic, or "zero-day" threats that they have never encountered before [15–17].

Integrating AI into cybersecurity offers a promising path to address these limitations [18,19]. Machine learning (ML) and deep learning (DL) can analyze large, complex datasets to detect patterns and anomalies that are difficult to capture with static rules or manual inspection [20]. Accordingly, this review focuses on two core applications: (i) vulnerability detection (e.g., automated code analysis, vulnerability report classification, and network anomaly detection) [21,22], and (ii) vulnerability mitigation and patching (e.g., risk-based prioritization and, more recently, large language model (LLM)-assisted patch suggestion) [23,24].

However, the use of AI for vulnerability management is a field that has not yet been fully developed. The academic publications are diverse and each of them reveals a complex state with different models, small datasets, and varying metrics for evaluation. Therefore, it is difficult for researchers and security practitioners to grasp the effectiveness of these solutions in real-life scenarios. A significant gap exists in the literature: there is no systematic synthesis that critically evaluates the comparative effectiveness, methodological, and practical challenges of AI-driven vulnerability detection and patching systems.

Several surveys and mapping studies already exist on adjacent topics, including (i) automated vulnerability detection and related tasks such as program repair and defect prediction [25], (ii) deep learning for source-code vulnerability analysis [26], and (iii) software security patch management practices and challenges [14]. In addition, some recent works provide conceptual or tool-oriented frameworks for AI-assisted security assessment and analysis (e.g., [5,27,28]). Nevertheless, these studies typically emphasize either detection (often source-code focused) or patch management at a process level, and they rarely synthesize detection and mitigation together under a single PRISMA-governed protocol while also foregrounding modern trends such as LLM-assisted remediation and DRL-based dynamic prioritization. Furthermore, many surveys do not include a consistent, study-level quality appraisal that allows readers to interpret performance claims in light of dataset quality, evaluation design, and reproducibility. Accordingly, our review contributes a PRISMA-registered, end-to-end synthesis spanning vulnerability detection and patching/mitigation, with explicit attention to heterogeneity, study quality, and the practical barriers to deployment (e.g., generalizability, robustness, and explainability).

Contributions. Specifically, this review:

- Follows a PRISMA 2020-compliant and OSF-registered protocol to identify and synthesize AI approaches for both detection and mitigation/patching;
- Provides a structured taxonomy and cross-study synthesis covering text-based triage, source-code analysis, network anomaly detection, risk scoring/prioritization, DRL policies, and LLM-assisted remediation;
- Restricts quantitative comparisons to clearly comparable clusters and otherwise uses a structured qualitative synthesis to address heterogeneity and study quality;
- Critically analyzes recurring limitations that govern real-world reliability, including dataset/benchmark gaps, generalizability, adversarial robustness, and the need for explainability.

This systematic review addresses this gap. This study presents an exhaustive exploration of the field's current state by combining and evaluating 29 primary studies published between 2019 and 2024. The main points of this research are the answers to the questions below (RQs).

These contributions are operationalized through the following research questions, which target AI techniques for detection and mitigation, as well as the methodological and deployment constraints that explain why high reported performance often fails to translate into practice:

- RQ1: What AI techniques are used for vulnerability detection, and how are they applied to tasks like text classification, source code analysis, and network anomaly detection?
- RQ2: What AI techniques are used for vulnerability mitigation, specifically for patch prioritization and automated patch generation?
- RQ3: What are the key challenges and limitations (e.g., dataset bias, model generalizability, adversarial robustness) that affect the real-world reliability of these AI systems?
- RQ4: What is the role of emerging trends, particularly large language models, in this domain?

The remainder of this paper is organized as follows: Section 2 details our methodology. Section 3 provides a brief overview of the traditional approaches that serve as a baseline. Section 4 introduces the core AI concepts. Sections 5 and 6 present our core analysis, systematically synthesizing the literature on AI for detection and patching, respectively. Section 7 provides a comparative analysis of AI versus traditional methods. Section 8 offers a critical discussion of the field's challenges, directly addressing RQ3. Section 9 explores emerging trends, with a specific focus on LLMs to address RQ4. Finally, Section 10 concludes this paper with key findings and implications.

2. Methodology

In this section, we detail the literature review process used to select and extract articles that address our research objectives. We describe each step with sufficient transparency to support clarity and reproducibility.

The review protocol was registered on the Open Science Framework (OSF) (Registration No.: eah69 (https://osf.io/eah69) registered and accessed on 11 December 2025). This systematic review follows the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) 2020 guidelines [29,30], and the completed PRISMA 2020 checklist is provided in Supplementary Table S2. The eligibility criteria were carefully defined to select studies relevant to the research objectives, focusing on AI-driven solutions for vulnerability detection and patching.

2.1. Eligibility Criteria

Inclusion Criteria:

- Type: peer-reviewed journal articles and conference papers.
- Date: studies published between 1 January 2019 and 30 September 2024. This timeframe was selected to capture the most recent advancements, aligning with the publication dates of our final included studies.
- Focus: studies that explicitly apply AI, ML, DL, or LLM techniques to vulnerability detection, classification, prioritization, or automated patching.
- Language: articles written in English.

Exclusion Criteria:

- Duplicate studies or those with insufficient methodological details.
- Non-peer-reviewed articles (e.g., editorials, opinions, blogs).
- Studies focusing on unrelated AI applications (e.g., malware detection, network intrusion without a vulnerability focus).

A comprehensive literature search was conducted across six major electronic databases: IEEE Xplore, ACM Digital Library, ScienceDirect (Elsevier), SpringerLink, Scopus, and Web of Science Core Collection.

2.2. Search Execution and Database Yields

To ensure full reproducibility of this review, we recorded the exact search date, database-specific search constraints, and the number of retrieved records for each database. Table 1 reports the database-by-database yields used to construct the PRISMA flow diagram.

Table 1. Database search log and record yield (reproducibility summary).

Database	Search Date	Fields/Filters	Records
IEEE Xplore	29 October 2024	Advanced query; publication years 2010–2024; English; peer-reviewed venues (journals/conferences).	165
ACM Digital Library	29 October 2024	Title/Abstract query; publication years 2010–2024; English; peer-reviewed venues.	234
SpringerLink	29 October 2024	Full-text query; publication years 2010–2024; English; peer-reviewed venues.	563
ScienceDirect (Elsevier)	29 October 2024	Full-text query; publication years 2010–2024; English; peer-reviewed venues.	22
Scopus	29 October 2024	TITLE-ABS-KEY query; publication years > 2010; English; peer-reviewed venues.	181
Web of Science Core Collection	29 October 2024	Topic (TS) query; publication years 2010–2024; English; peer-reviewed venues.	78
Total			1243

The search strategy combined keywords related to AI and vulnerability management using Boolean operators (AND, OR). An example of the search strategy applied to IEEE Xplore is shown in Table 2, while Table A1 summarizes the database-specific search configurations. The complete search strings for all databases are provided in Appendix A.

Table 2. Example search strategy (IEEE Xplore).

Database	Example Search Strategy
IEEE Xplore	(("Artificial Intelligence" OR "Machine Learning" OR "Deep Learning" OR "Large Language Models") AND ("Vulnerability Detection" OR "Vulnerability Patching" OR "Vulnerability Management" OR "Code Analysis"))

2.3. Study Selection Process and Disagreement Resolution

The study selection followed PRISMA-based stages, as illustrated in Figure 1. Screening was performed by the authors using the predefined inclusion and exclusion criteria. Any disagreements were resolved through discussion until consensus was reached.

1. Identification: database searching identified 1243 records (Table 1).
2. Screening: after 317 duplicates were removed, the titles and abstracts of the remaining 926 records were screened.
3. Eligibility: the full texts of 109 articles were assessed, leading to the exclusion of 80 articles for not meeting the inclusion criteria (e.g., wrong focus, non-peer-reviewed).
4. Inclusion: this process yielded a final selection of 29 studies for inclusion in the qualitative and quantitative synthesis.

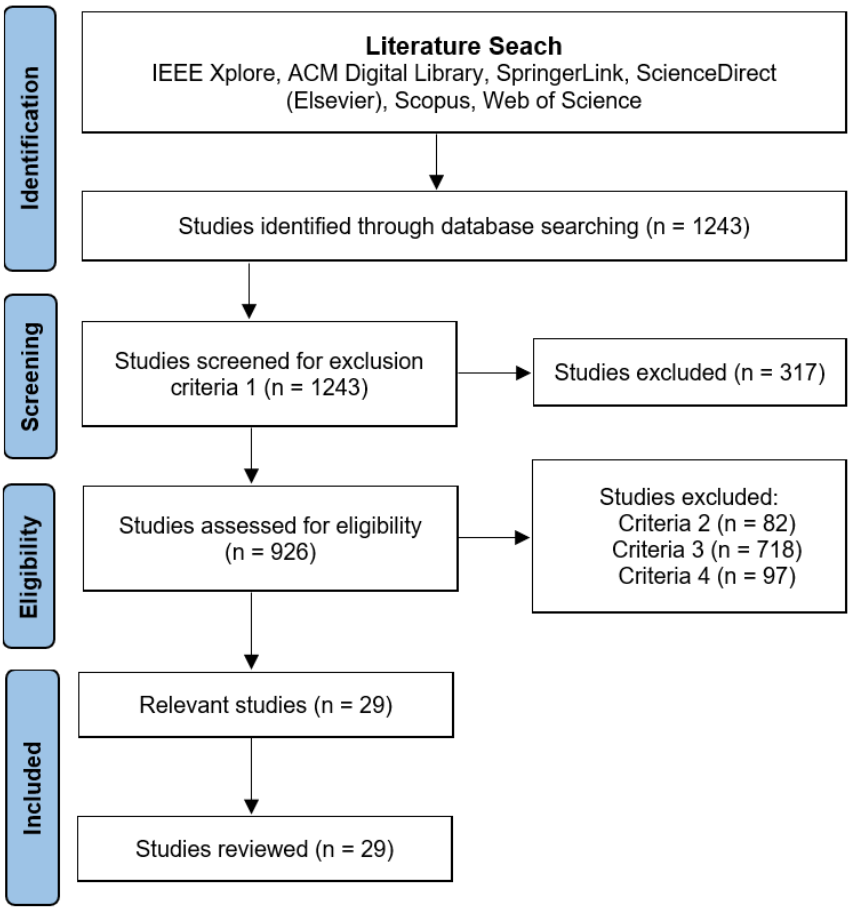


Figure 1. PRISMA 2020 flow diagram of study selection.

Figure 2 presents the distribution of the 29 selected papers by year of publication, illustrating the recent growth of interest in this topic. Table 3 lists the paper IDs corresponding to Figure 2.

Table 3. Papers by year of publication.

Year	Number of Papers	Related Paper
2019	2	[31,32]
2020	6	[9,13,33–36]
2021	4	[5,21,37,38]
2022	3	[22,39,40]
2023	8	[4,10,16,23,24,41–43]
2024	6	[15,27,28,44–46]

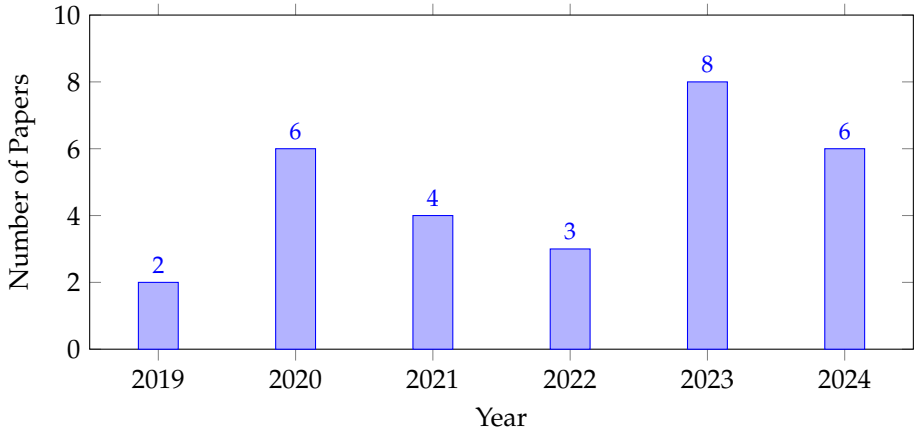


Figure 2. Number of papers by year of publication.

2.4. Study Characteristics of Included Studies

To support transparent reporting of the included evidence base, we summarize the key study characteristics extracted from the included studies during data extraction. Figure 3 provides the thematic distribution of research objectives, while Table 4 details each study's objective, technique, dataset, and reported outcomes. Most studies proposed fully automated pipelines (n = 26), with a smaller set adopting semi-automated or human-in-the-loop designs (n = 3). In terms of methodological framing, 16 studies were fully AI-based, 10 adopted hybrid designs, and 3 provided traditional baselines. Regarding data grounding, 17 studies relied solely on public datasets, 4 combined public and private data, 4 used private/real-world datasets, 3 used simulated or synthetic data, and 1 did not clearly report dataset provenance. The NVD was the dominant data source (n = 14), followed by Exploit-DB (n = 5) and CISA-related datasets/alerts (n = 2); code-centric studies predominantly evaluated on C/C++ corpora (e.g., Big-Vul, Reveal, SARD), while network-focused studies used established traffic benchmarks (e.g., CICIDS2017, NSL-KDD). Table 5 provides a high-level summary of the included studies' characteristics.

Table 4. Comprehensive synthesis of included studies on AI in vulnerability detection and patching. Key metrics are reported as stated in the original papers and are not directly comparable across heterogeneous tasks/datasets.

Paper	Year	Primary Objective	AI Technique(s)	Vulnerability Category	Dataset(s) Used	Key Metric	Key Limitation/Gap
[21]	2022	Text Classification	Self-Attention DNN, Bi-LSTM	CVE Descriptions	CVE Details	0.678 F1-Score (13-class)	Dataset limitations (imbalanced, duplicates).
[37]	2022	Non-AI Baseline	(Traditional)	OS (Ubuntu)	NVD, MITRE, Exploit-DB	System monitoring	Lacks generalizability (Ubuntu-only); not AI.
[9]	2020	Vulnerability Prediction	DNN, Topic Modeling (TSEM)	NVD Vulnerabilities	NVD	69–78% Accuracy	Lower accuracy on word-level regression.
[27]	2024	Framework/ Review	Hybrid (AI + OS Tools)	Web Applications	HackThisSite, Mutillidae	Qualitative	Very long scan times (5–10 h).
[33]	2020	Text Classification	BERT (Transfer Learning)	CVE Descriptions	NVD, Exploit-DB	91.12% Accuracy	Ignores other contextual factors.
[34]	2020	Text Classification	Random Forest, Boruta	CWE Classification	NVD	96.92% Accuracy	Lacks generalizability (limited to 19 CWEs).
[15]	2024	LLM (Detection/Gen.)	LLMs (GPT, T5, BERT)	Zero-Day Vulns.	CISA Dataset	Qualitative benchmark	Lacks generalizability (struggled on unrecorded vulns).
[35]	2020	Framework/ Review	Ontology, NLP	CVEs & Social Media	NVD, Twitter	95% Accuracy	Relied on manual tagging; low recall.
[36]	2020	Non-AI Baseline	(Traditional)	Critical Infrastructure	Real-world Attack Data	Policy-based	Lacks generalizability (not AI; static logic).
[28]	2024	LLM (Detection)	LLMs (BERT, GPT, RoBERTa)	Web Applications	(Not Stated)	Metrics not reported	Conceptual; no quantitative results.

Table 4. *Cont.*

Paper	Year	Primary Objective	AI Technique(s)	Vulnerability Category	Dataset(s) Used	Key Metric	Key Limitation/Gap
[16]	2023	Network Detection	Deep Reinforcement Learning	Network Vulns.	Simulated	95% Accuracy, 96% Recall	Dataset limitations (relies on simulated data).
[23]	2023	Mitigation/ Prioritization	Deep Reinforcement Learning (PPO)	Resource Allocation	Real-world CSOC	Policy-based	Lacks generalizability (trained in simulator).
[31]	2019	Network Detection	Stacked Denoising Autoencoder	Web (SQLi, XSS)	Custom (RSMT tool)	0.918 F1-Score	High runtime overhead; limited to Java JVM.
[13]	2024	Non-AI Baseline	(Traditional)	Corporate Network	NVD, Nessus Scans	22 ms Latency	Not AI; logic is based only on static CVSS.
[41]	2023	Non-AI Baseline	(Traditional)	System Configurations	NVD, Exploit-DB	Policy-based	Not AI; relies on static Feature Model logic.
[5]	2021	Framework/ Review	Explainable AI (XAI), HITL	IoT & Software	(N/A)	Conceptual framework	Purely conceptual; no empirical results.
[39]	2022	Mitigation/ Prioritization	Neuro-Symbolic AI	Network Vulns.	NVD, CISA Alerts	0.926 AUC	Relies on historical data; adversarial robustness not tested.
[24]	2024	LLM (Code Det./Repair)	LLMs (GPT-3.5, GPT-4)	C Code (Buffer Overflow)	Synthetic	Qualitative	Dataset limitations (synthetic data); no metrics.
[4]	2023	Text Classification	ML (RF, AdaBoost) & OSINT	OSINT Leaks	Public OSINT data	0.00 F1 (Critical Class)	Poor performance on the most critical class.
[40]	2022	Text Classification	Convolutional Neural Net (CNN)	CVE Descriptions	NVD, Exploit-DB	0.92 AUC (Exploitability)	Dataset limitations (limited 'Critical' data).
[44]	2024	Code Detection	RL + CodeBERT (LLM)	C/C++ Code	Big-Vul, Reveal	90.11% F1 (Big-Vul)	Lacks generalizability (C/C++ only).
[32]	2019	Text Classification	NLP, ML (BayesNet)	CVE Descriptions	NVD	81% F1-Score	Only analyzes text; does not incorporate CVSS scores.
[42]	2022	Mitigation/ Prioritization	ML (RF) + Integer Programming	CSOC Vulns.	Real-world CSOC	Policy-based	Dataset limitations (single, private dataset).
[10]	2023	Framework/ Review	ML (Naive Bayes, LR)	Fake News (Case Study)	Fake.csv	99.22% Accuracy	Case study is on fake news, not vulnerabilities.
[43]	2023	Text Classification	FastText (NLP)	CWE Classification	NVD	0.78 F1-Score (Average)	Lacks generalizability (limited to Top-25 CWEs).
[22]	2024	Code Detection	Bidirectional RNN (DL)	C Code	SARD, FFmpeg	97.2% F1-Score	Lacks generalizability (C-code only; must be compilable).
[45]	2024	Text Classification	RoBERTa (LLM)	CWE Classification	NVD	0.885 Accuracy (Tier 1)	Performance depends on NVD data quality.
[38]	2021	Text Classification	ML (RF, SVM, KNN)	Web Applications	DRUPAL, PKDD, CSIC	0.97 Prec/0.91 Rec (RF)	Performance is highly sensitive to dataset quality.
[46]	2024	Network Detection	Dynamic LSTM (DL)	Network Anomaly	CICIDS2017, NSL-KDD	99.25% Accuracy	Lacks generalizability (only network traffic).

Table 5. Summary of study characteristics (n = 29).

Characteristic	Count
Approach: AI-based	16
Approach: Hybrid	10
Approach: Traditional baseline	3
Automation: Full-automated	26
Automation: Semi-automated	3
Dataset provenance: Public	17
Dataset provenance: Mixed (public + private)	4
Dataset provenance: Private/real-world	4
Dataset provenance: Simulated/synthetic	3
Dataset provenance: Not stated	1

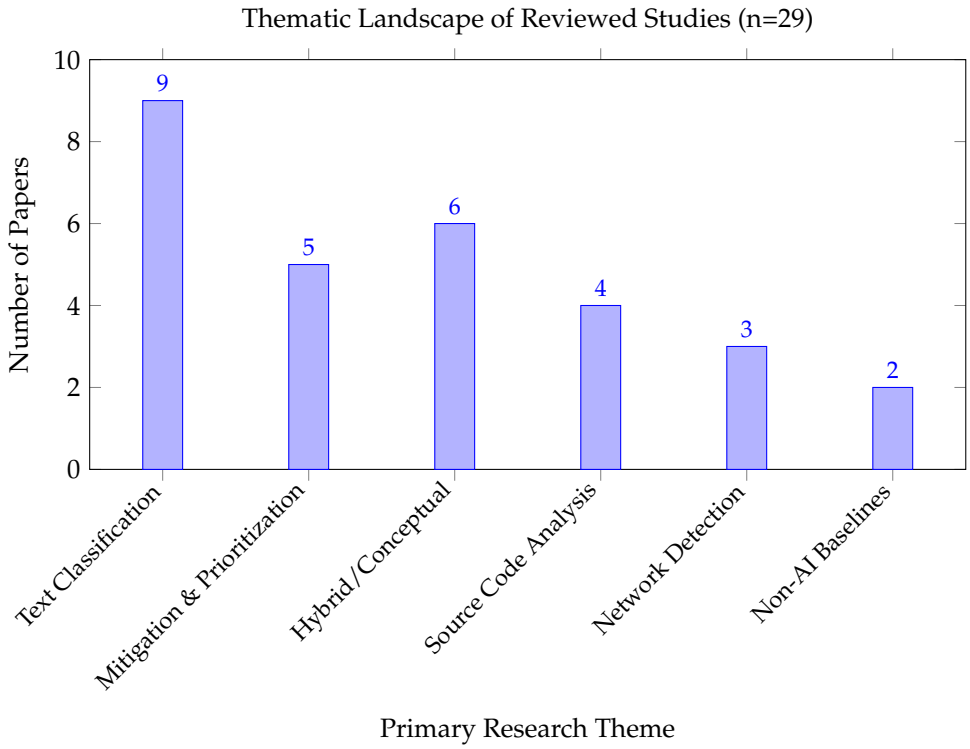


Figure 3. Thematic categorization of the 29 included studies, showing the distribution of research focus. "Text Classification" is the most common theme, while "Non-AI Baselines" represent the traditional frameworks used for comparison.

The primary data items extracted from each study were aligned with the research objectives:

- Bibliographic details: authors, publication year, title.
- Methodological details: study design, AI techniques and models used (e.g., RF, CNN, LLM), and evaluation methods.
- Application context: specific cybersecurity domain (e.g., source code analysis, network detection, CVE classification).
- Datasets: source, size, and nature (public or proprietary) of datasets used.
- Performance metrics: reported measures, such as accuracy, precision, recall, and F1-score.
- Key findings and limitations: main results and limitations noted by the authors.

Data extraction was conducted according to the predefined data items described above. Both authors independently extracted and verified the study information, and any discrepancies were resolved through discussion until a consensus was reached.

2.5. Quality Appraisal and Risk-of-Bias Assessment

To strengthen the systematic nature of this review and contextualize evidence strength, we conducted a structured quality appraisal (risk-of-bias assessment) of all included studies. A domain-tailored rubric was used to account for common threats in AI-driven vulnerability research (dataset artifacts, limited reporting, and evaluation design).

Seven criteria (C1–C7) were assessed: dataset transparency/representativeness, leakage control and validation protocol reporting, evaluation rigor (metrics and baselines), external validation/generalizability evidence, reproducibility transparency, robustness/stress testing considerations, and explicit limitations/threats to validity. Each criterion was scored as 0 (not satisfied), 0.5 (partially satisfied), or 1 (fully satisfied), for a maximum total

score of 7. Studies were grouped into evidence tiers: High ($\geq$5.0), Medium (3.5–4.5), and Low ($\leq$3.0).

The authors performed the appraisal and resolved disagreements through discussion until a consensus was achieved. The complete scoring matrix (criteria definitions and study-level scores) is provided in Supplementary Table S1. Evidence tiers were used to qualify conclusions and to restrict quantitative comparisons to clearly comparable clusters; otherwise, structured qualitative synthesis was prioritized.

Across the 29 included studies, 12 were categorized as High evidence, 13 as Medium, and 4 as Low (Supplementary Table S1). The most frequent sources of bias/weakness were limited external validation (single-dataset or simulated settings) and the absence of robustness/adversarial evaluation, which we explicitly consider when interpreting performance claims in Sections 5–9.

Importantly, the evidence tiers were applied explicitly during interpretation: findings supported primarily by high- and medium-evidence studies were emphasized as more reliable, while the results from low-evidence studies were treated as provisional and used mainly to illustrate emerging directions or hypotheses rather than to support strong comparative claims.

Due to the significant heterogeneity of AI techniques, datasets, label spaces, and evaluation protocols, a single pooled quantitative synthesis was not feasible. Therefore, we used a structured, mixed-method synthesis for data synthesis.

1. Thematic grouping: studies were categorized based on their primary technical objective (e.g., text-based classification, source code analysis, network anomaly detection, management & prioritization).
2. Quantitative synthesis: for groups with comparable tasks (e.g., CVE-to-CWE classification), a lightweight quantitative aggregation was performed; because AI techniques, datasets, label spaces, and evaluation protocols vary substantially across studies, quantitative comparisons were restricted to clearly comparable clusters (same task definition, compatible datasets/labels, and comparable metrics).
3. Structured qualitative synthesis: when comparability was uncertain, we prioritized a structured qualitative synthesis to address heterogeneity and study quality, and used the quality appraisal results to contextualize the strength of evidence.

3. Traditional Approaches to Vulnerability Detection and Patching

This section provides a concise baseline of traditional detection and patching approaches, focusing only on limitations that motivate and contextualize the AI-driven techniques reviewed in Sections 5–7.

The traditional methods of vulnerability detection and patching have been largely dependent on manual, rule-based, and signature-based techniques. Manual code review has been an essential part of software development processes. In this process, experts examine the source code to identify potential defects and security weaknesses [32,37]. However, this process is time-consuming, expensive, and prone to human error. Especially in large and complex codebases, developers can make mistakes due to fatigue and simple oversight [47–51]. Similarly, manual penetration testing relies on skilled security professionals attempting to exploit system weaknesses to uncover vulnerabilities; it is costly, time-bounded, and dependent on expert availability [27,52,53].

On the automated front, signature-based detection systems have been a foundational element of traditional security. These systems operate by comparing network traffic or system logs against a predefined database of known attack patterns, or "signatures" [17,46,54,55]. While effective at identifying well-known threats, their fundamental limitation is their reactive nature. They are, by definition, incapable of detecting

novel or modified attacks for which no signature yet exists. Rule-based intrusion detection systems (IDSs) operate on a similar principle, using predefined rules to identify malicious activities [16,56]. While structured, they require constant manual updates to their rulesets by human experts and lack the flexibility to identify new attack vectors that deviate from established patterns.

Finally, traditional patching processes are fraught with delays. The lifecycle from the initial discovery of a vulnerability to the vendor's development of a patch and to an organization's own internal testing, verification, and deployment can be time-consuming and error-prone. This entire process often takes weeks or even months, leaving a wide window of opportunity for attackers [13,37,57].

Despite their established role, these traditional approaches face several critical, overlapping challenges. Scalability issues are paramount. Manual methods simply cannot cope with the volume and complexity of modern software, which can span millions of lines of code across distributed microservices and CI/CD pipelines [4,9,58]. The proliferation of Internet of Things (IoT) devices further exacerbates this, creating an overwhelming number of endpoints to secure [10].

Slow detection and response times are the most significant drawback. The "window of opportunity" this slow pace provides to attackers is a primary driver of security breaches. Signature-based systems are always one step behind the attackers who create new exploits, making this reactive posture fundamentally ineffective against zero-day vulnerabilities [14–17,44].

Furthermore, traditional methods are heavily reliant on a small pool of skilled cybersecurity experts and are susceptible to human error. Security teams are often overwhelmed by "alert fatigue" from the high volume of low-fidelity alerts generated by static tools, leading to critical vulnerabilities being missed or mis-prioritized [11,38,42].

Lastly, these systems lack adaptability. They are static, limited by predefined rules and signatures, and are unable to adapt to polymorphic threats or novel attack patterns. As attackers increasingly utilize AI to identify and exploit vulnerabilities [59], this static, reactive defense model has become untenable. These limitations, summarized in Table 6, underscore the need for better, smarter, and more automated solutions.

Table 6. Challenges of traditional approaches.

Challenge	Description	Related Paper(s)
Scalability Issues	Difficulty managing increasing data and system complexity	[4,9,10,58]
Slow Detection and Response	Long delays in vulnerability detection and patching	[13,14,44,57]
Human Error	Manual processes susceptible to oversights, alert fatigue	[32,38,42]
Lack of Adaptability	Inability to detect novel or zero-day threats	[15–17]
Limited Scope	Limited to known vulnerabilities, platform coverage	[14,17,37,57]

4. AI Methods and Applications in Cybersecurity

This section provides an overview of the core AI/ML concepts used in the reviewed studies and establishes the foundation for the subsequent analysis of AI-driven vulnerability detection and mitigation.

Artificial intelligence (AI) is a broad field of computer science that aims to enable systems to perform tasks typically associated with human intelligence, such as problem-solving and decision-making [38]. Machine learning (ML), a branch of AI, is the main part of these abilities. It focuses on systems that can learn from data without being told what to do. This review identifies three primary paradigms of ML techniques.

The most common method we found in our review is supervised learning. It entails training models on labeled data (for instance, a vulnerability report designated as "SQL

Injection") to forecast outcomes on novel, unobserved data. This model is well suited for classification tasks, such as predicting vulnerability severity [40], identifying CWE categories from text [34,38], or estimating exploitability [33].

Unsupervised learning, on the other hand, is used to find hidden patterns in data that do not have any labels. This method is particularly useful for anomaly detection because it can identify deviations from learned "normal" behavior. This is important for finding new, zero-day attacks in network traffic or web request logs that do not match any known signature [31,46].

Reinforcement learning (RL) is a dynamic method in which an "agent" learns to make the best choices by interacting with an environment and receiving rewards or punishments for what it does. This is a powerful way to make adaptive defense systems in the field of cybersecurity [16], or, as shown in [23], to make the complicated, sequential decisions that come with patching and prioritizing resources.

Based on these basics, our review finds a number of specialized AI methods. Deep learning (DL) is a more advanced type of ML that uses artificial neural networks with many layers to model complex, non-linear relationships in data. DL models work well with source code, vulnerability descriptions, and network logs because they are all types of sequential data. Recurrent neural networks (RNNs) and their variants (such as LSTMs) are examples of this. They can understand the order and context of tokens in a sequence [21,22].

Natural language processing (NLP) is a field of AI that is critical to this domain, as a vast amount of vulnerability data are communicated in unstructured text (e.g., CVE reports, developer comments). NLP techniques are used to extract, classify, and summarize this data, automating tasks that would otherwise require manual human analysis [32,43,45].

Large language models (LLMs), such as BERT, RoBERTa, and GPT, represent the current state of the art in NLP. These models are pre-trained on massive text and code corpora, giving them a deep semantic understanding of both natural language and, increasingly, programming languages. This allows them to perform complex tasks like identifying subtle logical flaws in code or generating human-readable threat intelligence reports [15,24,28].

Finally, neuro-symbolic computing is an emerging trend that combines the pattern-matching strengths of neural networks with the formal, auditable logic of symbolic AI. This hybrid approach is promising for high-stakes tasks like risk prioritization, as it allows a model to not only predict a risk but also explain its reasoning based on logical rules [39].

These techniques are applied across diverse cybersecurity domains to enhance or replace traditional methods. Table 7 provides a summary of these core techniques and their primary applications as identified in our review. This table serves as a conceptual roadmap for the detailed analysis presented in Sections 5, 6 and 9.

Table 7. AI techniques in cybersecurity and their applications.

AI Technique	Description	Example Application(s)
Machine Learning	Algorithms learn from data for prediction	Vulnerability classification [33,34,40]
Unsupervised Learning	Identifies patterns in unlabeled data	Anomaly detection [31,46]
Reinforcement Learning (RL)	Agents learn through interaction with the environment	Dynamic threat response [16,23]
Deep Learning	Uses neural networks for complex analysis	Code analysis, complex pattern detection [21,22,40]
Natural Language Processing (NLP)	Processes and analyzes textual data	Vulnerability reports, log analysis [32,43,45]
Large Language Models (LLMs)	Understands and generates text and code	Code analysis, threat intelligence [15,24,28]
Neuro-symbolic Computing	Combines neural networks with logical reasoning	Vulnerability prioritization [39]

5. AI Techniques for Vulnerability Detection

In this section, we synthesize the findings related to our first research question (RQ1), analyzing how AI techniques are applied to the detection of vulnerabilities. Traditional detection methods are ill-suited for the scale and speed of modern security. The studies in our review demonstrate a clear trend towards using AI for three distinct detection tasks: (1) the automated classification of textual vulnerability reports, (2) the analysis of source code to find underlying flaws, and (3) the real-time detection of network anomalies and attacks.

Table 4 summarizes study-level characteristics; the discussion below synthesizes cross-study findings and implications for RQ1.

Automated classification of vulnerability reports: A large part of the literature that was reviewed is about using AI to automate the triage and classification of text-based vulnerability reports, like those in the National Vulnerability Database (NVD). This is a classic natural language processing (NLP) problem that supports scalable triage of daily alert volumes that can exceed human analysts' capacity. The studies show that technical methods have changed over time. Across text-based triage and CWE/CVE-related classification tasks, the literature shows a clear progression from traditional ML with engineered features toward deep and transformer-based models that reduce manual feature engineering and better capture semantic context. For comparable task clusters, Table 8 reports representative quantitative results, which we use to synthesize cross-study trends and limitations. Because the included studies use different tasks, label spaces, datasets, and metrics, the reported values should be interpreted within-study (as evidence of feasibility) rather than as a direct cross-study ranking.

Table 8. Reported evaluation results for vulnerability classification studies (metrics are reported as in the original papers and are not directly comparable across heterogeneous tasks/datasets).

Paper	AI Technique(s)	Task	Dataset(s)	Key Reported Metric
[34]	Random Forest, Boruta	CWE Classification (19 classes)	NVD	96.92% Accuracy
[38]	Random Forest, KNN, SVM	Web Vuln. Classification	DRUPAL, PKDD2007	0.97 Precision, 0.91 Recall (RF)
[32]	BayesNet, RF, J48	CVE Description Summary	Custom CVE dataset	81% F1-Score (BayesNet)
[43]	FastText	CWE Tagging (Top-25)	NVD	0.78 F1-Score (Average)
[21]	Self-Attention DNN, Bi-LSTM	Vulnerability Type Classification	CVE Details	0.678 F1-Score (13-class)
[33]	ExBERT (BERT Transfer Learning)	Exploitability Prediction	NVD, Exploit-DB	91.12% Accuracy, 91.82% Precision
[45]	VulnBERTa (RoBERTa)	CWE Assignment (160 classes)	NVD	0.885 Accuracy (Tier 1)

AI-driven source code analysis: Beyond classifying reports, a more complex task is the direct analysis of source code to find vulnerabilities before they are compiled. This requires a deeper understanding of code structure, logic, and data flow. The reviewed studies show a move toward sophisticated DL and reinforcement learning (RL) models for this purpose. Ref. [22] introduced VulDeeLocator, a system that treats code as a sequential-data problem. It employs a bidirectional recurrent neural network (BRNN) to analyze programs, not as raw text, but as intermediate code representations. This allows the model to capture deeper semantic and syntactic properties of the code, leading to a 9.8% improvement in F1-score over previous approaches. Critically, it also dramatically improved locating precision, pinpointing the exact vulnerable lines of code. In a novel approach, ref. [44] proposed

ProRLearn to address the rigidity of standard model fine-tuning. The system first uses a pre-trained model (CodeBERT) with prompt tuning, but then adds a reinforcement learning (RL) agent. This agent learns an optimal policy to dynamically refine the model's predictions, rewarding it for correct classifications. This hybrid RL-DL approach yielded significant F1-score improvements (up to 70.96%) on benchmark C/C++ datasets like Big-Vul.

Network anomaly and zero-day detection: The third detection theme identified is the use of AI for real-time network security. Unlike static code analysis, this focuses on dynamic, "in-the-wild" threats. The primary goal here is to detect anomalies that deviate from a learned baseline of normal behavior, a key strategy for identifying zero-day attacks that bypass static signatures. The reviewed studies use several different AI strategies to accomplish this. Ref. [31] employed an unsupervised approach, using a stacked denoising autoencoder to analyze application call traces. By learning to reconstruct "normal" execution flows, it can effectively flag any deviation—such as an SQL Injection or XSS attack—as an anomaly, achieving a high F1-score of 0.918. For detecting exploits in network traffic (a time-series problem), ref. [46] proposed a Dynamic LSTM-based Anomaly Detection (DLAD) model. The LSTM's stateful nature allows it to model temporal patterns in network traffic, and its dynamic adaptation mechanism helps it adjust to changing patterns, achieving 99.25% validation accuracy on the CICIDS2017 and NSL-KDD datasets. Finally, ref. [16] utilized deep reinforcement learning (DRL) for a more adaptive defense. In this framework, a DRL agent is trained to not only passively detect but also actively respond to network vulnerabilities in real-time. The system achieved 95% detection accuracy and 96% recall, demonstrating a sophisticated model that can adapt its detection strategy as the threat landscape evolves.

Cross-study synthesis and implications: Across the three detection themes, performance claims are driven as much by data and task design as by model choice. Text-based classifiers typically report strong scores when the label space is constrained (e.g., limited CWE sets) and the dataset is aligned with the training distribution [34,43], whereas performance degrades for highly imbalanced or operationally critical classes [4] and when evaluation protocols differ across datasets. For source-code analysis, models that leverage richer program representations or code-pretrained encoders improve line-level localization and reduce false alarms, but they remain language- and dataset-bound (primarily C/C++) [22,44]. In network settings, anomaly detectors and DRL-based defenders can achieve high accuracy in benchmark or simulated environments [16,46], yet their real-world reliability depends on whether the learned normal baseline transfers to new traffic regimes and whether adversarial robustness is assessed (Section 8). These patterns motivate our conservative quantitative aggregation policy and the emphasis on study quality and external validity in the synthesis.

6. AI in Patching and Vulnerability Mitigation

Once a vulnerability is detected, organizations face the equally critical challenge of mitigation. This section addresses our second research question (RQ2) by analyzing how AI is applied to the post-detection phases of vulnerability management. The reviewed literature shows that the core challenge is not merely patching, but prioritization and resource allocation. With security teams facing thousands of vulnerabilities, AI is being used to move beyond static scoring and toward intelligent, context-aware mitigation strategies. We synthesize the findings into three main themes: (1) ML-driven risk scoring, (2) DRL for dynamic resource management, and (3) LLMs for automated remediation.

Table 9 and Figure 4 summarize study-level mitigation approaches; the narrative below synthesizes cross-study findings and implications for RQ2.

Table 9. Synthesis of AI-driven vulnerability mitigation and prioritization techniques.

Paper	AI Technique(s)	Task	Key Innovation
[13,41]	(Traditional Baseline)	Prioritization	Automated static logic (CVSS, Feature Models)
[42]	Machine Learning (RF)	Prioritization (Triage)	Context-aware scoring (asset value, analyst skill, environment factors)
[40]	Deep Learning (CNN)	Prioritization (Scoring)	Predicts exploitability & severity directly from textual CVE descriptions
[39]	Neuro-Symbolic AI	Prioritization (Risk)	Combines neural-pattern learning with symbolic reasoning rules
[23]	Deep Reinforcement Learning (PPO)	Dynamic Management	Optimizes resource allocation over time under uncertainty
[15,24]	Large Language Models (LLMs)	Automated Remediation	Generates human-readable explanations and proposes vulnerability repairs/code fixes

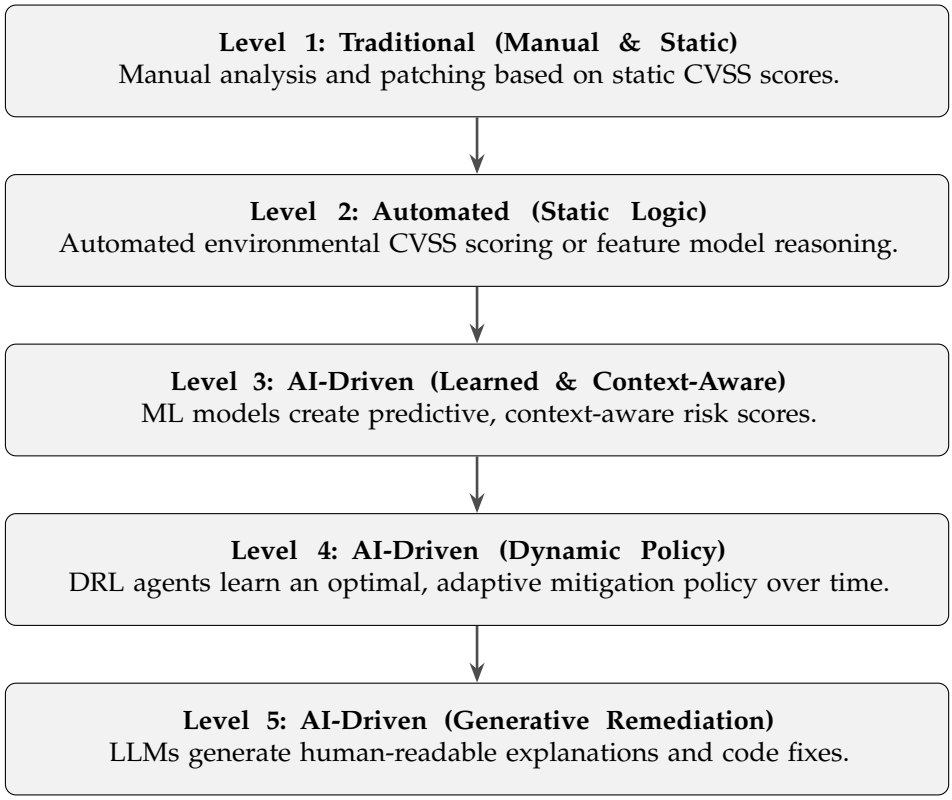


Figure 4. The evolution of vulnerability mitigation strategies identified in this review. The trend progresses from static, manual processes (Level 1), to automated but rigid logic (Level 2; e.g., VMC [13] and AMADEUS-Exploit [41]), and finally to AI-driven systems that are context-aware (Level 3; e.g., VPSS [42] and LICALITY [39]), dynamic (Level 4; e.g., Deep VULMAN [23]), and generative (Level 5; e.g., LLM-based remediation approaches [15,24]).

Limitations of traditional vs. AI-driven prioritization: Traditional prioritization, while often automated, is typically static. Methods like the Common Vulnerability Scoring System (CVSS) provide a base score but lack organizational context [13,42]. Studies in our review proposed automated but non-AI frameworks to improve this, such as using Feature Models to map exploits to system configurations [41] or distributed systems to calculate CVSS environmental scores [13]. However, these approaches still rely on predefined, static logic. AI-driven approaches, in contrast, learn complex, context-specific patterns to create a more accurate and dynamic risk posture.

Machine learning for advanced risk scoring: A key application of AI is to create superior, context-aware risk scores. Instead of just using a CVE's base score, these models learn to predict the true risk to an organization. Ref. [42] introduced a Vulnerability Priority Scoring System (VPSS) that uses ML models (like Random Forest) to generate a priority score based on rich contextual data, including asset criticality, network location, and even the skills of the available security analysts. Similarly, ref. [40] used Convolutional Neural Networks (CNNs) to predict both the severity and, more importantly, the exploitability of a vulnerability directly from its textual description, achieving a high AUC of 0.92. Perhaps the most advanced approach in this category is LICALITY [39], a neuro-symbolic system. It combines a neural network (to learn from data) with probabilistic logic programming (to incorporate expert rules), allowing it to reason about both the "Likelihood" and "Criticality" of an exploit. This hybrid model was shown to reduce the remediation workload by a factor of 2.89 compared to CVSS-based methods.

Deep reinforcement learning for dynamic management: While ML scoring improves prioritization at a single point in time, deep reinforcement learning (DRL) addresses the dynamic nature of vulnerability management. Security operations are a sequential decision-making problem under uncertainty, which is an ideal use case for DRL. Ref. [23] introduced Deep VULMAN, a framework that uses a DRL agent (based on Proximal Policy Optimization, PPO) to create a dynamic resource allocation policy. The agent learns from a simulated environment to decide which vulnerabilities to mitigate based on stochastic arrivals, resource constraints, and asset values, demonstrating a sophisticated, adaptive strategy that static scoring cannot achieve.

Emerging role of LLMs in automated remediation: The most forward-looking application of AI in mitigation is the use of LLMs for automated patch generation and repair. While most studies focus on detection, a few demonstrate the potential for remediation. Ref. [24] used LLMs like ChatGPT-3.5 to not only detect buffer overflows in code but also to provide human-readable explanations and generate the corresponding fix (e.g., suggesting the replacement of the unsafe "scanf" function with the safer "fgets"). This capability to "close the loop" from detection to repair is also noted in [15], where LLMs are benchmarked for their ability to provide "actionable insights and mitigation recommendations." This trend points toward a future where AI not only finds flaws but also actively participates in fixing them. A summary of these mitigation approaches is presented in Table 9.

Mitigation synthesis and implications: The mitigation literature collectively indicates a progression from static scoring to context-aware and policy-based decision making. ML-based scoring systems integrate operational context (asset value, environment, analyst capacity) to reduce wasted remediation effort [39,42], while DRL frameworks explicitly model vulnerability management as a sequential allocation problem under uncertainty [23]. LLM-enabled remediation remains early-stage but is notable for shifting from ranking to actionable repair artifacts (explanations and patch suggestions) [15,24]. Importantly, across these approaches, the main barrier to operational deployment is not merely predictive accuracy but the joint requirement of reproducibility, generalizability across environments, and analyst trust (explainability), which we treat as first-order evaluation dimensions in Section 8.

7. Comparative Analysis of AI vs. Traditional Approaches

This section synthesizes the findings from Sections 3, 5 and 6 to contrast AI-driven and traditional approaches. Our examination of the 29 studies indicates that AI does not merely provide a marginal enhancement; it signifies a profound transformation in the management of vulnerabilities. The differences are most clear in three important areas: (1) accuracy

and adaptability of detection, (2) intelligence and response time of prioritization, and (3) scalability and efficiency. Table 10 shows a summary of these comparisons.

Table 10. Comparative analysis of traditional vs. AI-driven approaches.

Metric	Traditional Approaches (Baseline)	AI-Driven Approaches (Enhancement)
Detection Accuracy	Lower. Relies on known signatures and rules; high false positives [38,42].	Higher. Learns complex patterns; achieves high accuracy (e.g., 99.25% in [46]) and strong F1-scores (e.g., 0.918 in [31]).
Adaptability (Zero-Day)	Very low. Fundamentally reactive; cannot detect novel attacks by design [15,17].	High. Proactive by design. Unsupervised and deep learning models (LSTMs, autoencoders) excel at anomaly detection [16,31,46].
Prioritization	Static and generic. Relies on manual analysis or CVSS base scores [13].	Dynamic and context-aware. ML-based predictive scoring (e.g., VPSS [42], LICALITY [39]).
Scalability	Low. Dependent on human experts for code review [32] and manual triage [11].	High. AI models process large-scale datasets (NVD [45], codebases [22], OSINT [4]) automatically.
Response Time	Slow. Manual processes for patching and prioritization may take weeks or months [14,57].	Fast. AI enables real-time detection (e.g., 22 ms latency in [13]) and dynamic resource allocation (DRL) [23].

The discussion below highlights the most consistent differences observed across the reviewed evidence.

Comparison criteria: Given heterogeneous datasets and evaluation protocols, reported metrics are interpreted as study-specific and are not treated as directly comparable across heterogeneous tasks/datasets. We therefore compare AI and traditional approaches along three criteria grounded in the included studies: (i) detection capability (pattern learning vs. signature/rule matching), (ii) prioritization intelligence (static CVSS logic vs. context-aware or policy-based decisioning), and (iii) operational scalability and timeliness (automation, latency, and analyst workload). Where performance metrics are directly comparable, we report them; otherwise, we triangulate evidence using study objectives, dataset realism, and the quality appraisal (Supplementary Table S1).

Detection accuracy and adaptability: As shown in Section 3, most traditional detection methods are reactive. Signature-based systems can only find threats that have already been found [17,46], and rule-based systems are limited by the logic that people set up themselves [16,56]. Their main flaw is that they cannot find new or "zero-day" attacks. AI-driven detection models, on the other hand, are proactive because they are made to learn patterns instead of matching signatures. Unsupervised models, such as the stacked denoising autoencoder in [31], establish a baseline of "normal" application behavior and can identify any significant deviation (e.g., a novel SQL injection) as an anomaly, attaining a 0.918 F1-score without prior knowledge of attacks. In the same way, DL models like the LSTM in [46] learn the temporal patterns of network traffic, which lets them find zero-day attacks with 99.25%.

Prioritization intelligence and response time: Traditional methods for reducing vulnerabilities rely on static, general scoring, mostly the CVSS. Frameworks such as the Vulnerability Management Centre (VMC) [13] can automate the computation of environmental CVSS scores; however, the underlying logic is predetermined and does not possess predictive capabilities. As shown in Section 6, AI-driven prioritization is fundamentally more effective and more flexible. The first step in this process is to add context. Machine

learning models like the Vulnerability Priority Scoring System (VPSS) [42] make a detailed score that takes into account things like the importance of assets and even the skills of the security analysts who are available. The next step is to make it more predictive. The CNN-based model in [40] predicts how easy it is to exploit a vulnerability based on its text description (AUC 0.92). Neuro-symbolic AI is used by more advanced systems like LICALITY [39] to think about risk. This has been shown to cut the remediation workload by 2.89 times compared to CVSS. Finally, DRL frameworks like Deep VULMAN [23] go beyond static scoring to make a real-time mitigation policy that changes based on resource limits and new threats that emerge.

Scalability and efficiency: Manual methods like code review and penetration testing do not perform well on a large scale. Human-centered workflows remain a major bottleneck in traditional security: triaging large volumes of alerts and cyber threats is time-consuming and error-prone [11]. AI supports these workflows by automating repetitive tasks. For example, an NLP model like VulnBERTa [45] can automatically classify 160 different CWE types from the entire NVD, a task that would take substantial time if labeled manually by experts. VulDeeLocator [22] is a code analysis model that can look at millions of lines of C code, and OSINT models [4] can look at large volumes of open-source data. This automation lets human experts focus on high-level strategic defense instead of doing low-level, repetitive tasks like alert triage [32].

8. Challenges in AI-Driven Vulnerability Detection and Patching

Despite the clear advantages demonstrated in Section 7, the practical, real-world adoption of AI-driven vulnerability management faces significant challenges. This section addresses our third research question (RQ3) by providing a critical evaluation of the key limitations and barriers identified in the reviewed literature. These challenges must be overcome for these techniques to move from promising research to reliable industrial practice.

The Data-grounding problem: quality, availability, and benchmarks: The most significant and frequently cited limitation across the reviewed studies is the dependency on high-quality, large-scale, and representative datasets. AI models are only as good as the data they are trained on, and in cybersecurity, good data are exceptionally rare. Many studies rely on public, but aging, benchmark datasets like NVD, SARD, or network traffic datasets (e.g., CICIDS2017, NSL-KDD) [22,45,46]. While useful for academic comparison, these static datasets often contain labeling errors and may not accurately represent the complexity and "messiness" of modern, in-the-wild threats. This forces researchers to spend considerable effort on cleaning and preprocessing [45]. Figure 5 visualizes the frequency of these key challenges across the reviewed literature.

Even more problematic is the reliance on private, non-shareable, or synthetic data. Several studies note their use of proprietary corporate data [42], data from simulated environments [16,23], or small-scale synthetic datasets [24,31]. While this allows for novel research, it makes reproducibility and comparative benchmarking impossible. This "data-grounding problem" leads to a critical research gap: the lack of standardized, modern benchmarks for detection and patching. Without a common ground for evaluation, it is difficult to determine if a complex new model (e.g., [44]) is truly superior to a simpler one (e.g., [34]).

Model generalizability and overfitting: The problem of generalizability is closely related to the problem of data. A model that does well on a test set might not do well in the real world. A lot of the models that did well in our review are very specialized. VulDeeLocator [22] and ProRLearn [44] are two examples of tools that work well, but they were made and trained only for C/C++ source code. These tools cannot be used to find vulnerabilities in other languages like Python, Java, or C#. This specialization makes them

less useful. Moreover, models trained on limited or highly imbalanced data are susceptible to overfitting, a concern explicitly raised in [15].

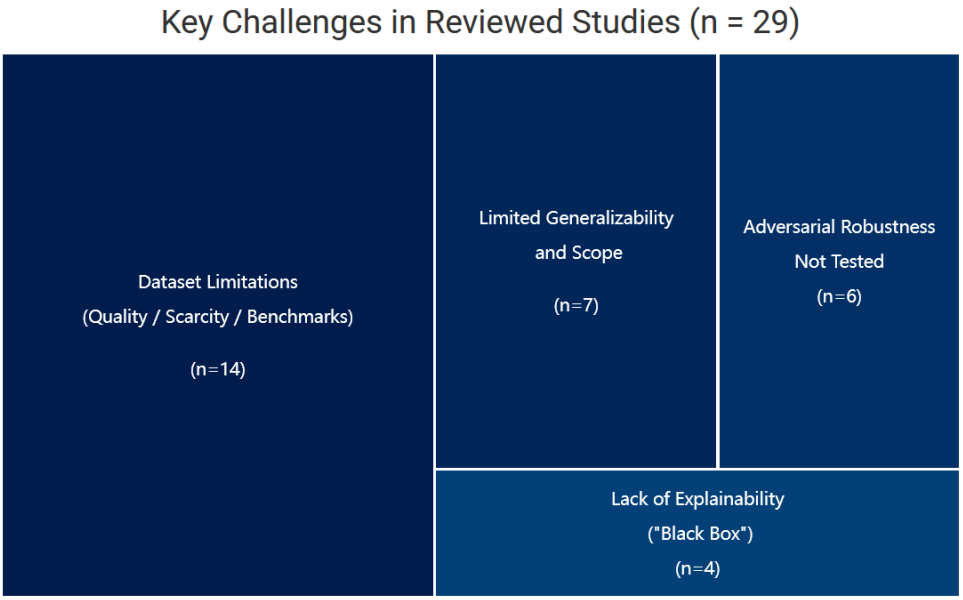


Figure 5. A treemap visualizing the frequency of key challenges and limitations cited in the 29 reviewed studies. Dataset-related issues were the most frequently mentioned limitation.

In the same way, models that work well in one environment may not work well in another. Network anomaly detectors trained on the specific traffic patterns of the CICIDS2017 dataset [46] or DRL agents trained in a particular simulated CSOC environment [23] are likely to be ineffective when implemented in a real-world corporate network with a different "normal" baseline. They need expensive retraining and fine-tuning by experts for each specific deployment environment, which makes them hard to use in real-world scenarios. Moreover, models trained on limited or highly imbalanced data are susceptible to overfitting, which can degrade performance when deployed on unseen systems or environments.

Adversarial Robustness: A unique and critical challenge for AI in cybersecurity is its vulnerability to adversarial attacks. Unlike traditional software, an AI model introduces a new, exploitable attack surface where the model itself becomes the target. Malicious actors can exploit this by covertly altering source code using semantically neutral inputs to mislead a DL-based detector [22], or by crafting network traffic that tricks an anomaly detector [46] into classifying malicious activity as "normal." Despite these risks, there is a significant gap in the reviewed literature. The vast majority of studies prioritize standard performance metrics (like accuracy) but fail to test their model's robustness against such attacks. This represents a critical blind spot; a model that achieves 99% accuracy but is easily deceived by adversarial perturbations is not a viable security tool.

The "Black Box" problem: explainability and trust: Finally, a major barrier to adoption is the "black box" nature of many complex AI models. In a high-stakes field like security, an alert that cannot be explained is not actionable. A security analyst cannot be expected to shut down a critical server or flag a developer's code as vulnerable based on a deep learning model's opaque output (e.g., from an LSTM [46] or Autoencoder [31]). This lack of transparency is a fundamental barrier to trust.

The literature itself is aware of this problem and is actively proposing solutions. The framework in [5] is built entirely around Explainable AI (XAI) and a "Human-in-the-Loop" (HITL) model, arguing that human oversight and model transparency are essential. The neuro-symbolic LICALITY model [39] is powerful precisely because its probabilistic logic

component is auditable, allowing an analyst to see the rules that contributed to a risk score. This is also a key promise of LLMs, which can provide "human-readable explanations" and "recommended mitigations" for the vulnerabilities they find [24], moving beyond a simple "vulnerable/not-vulnerable" binary. These challenges are summarized in Table 11.

Table 11. Challenges of AI in cybersecurity vulnerability management.

Challenge	Description	Related Papers
Data Quality and Availability	Lack of diverse, large-scale, and representative public datasets for training and benchmarking.	[5,42]
Dataset Issues	Reliance on private, synthetic, or aging benchmark datasets, hindering reproducibility and fair comparison.	[16,23,24,31,46]
Model Generalizability	Models trained for one domain (e.g., C code) or environment (e.g., simulated networks) often fail to transfer effectively to others.	[16,22,23,44,46]
Adversarial Robustness	AI models can be manipulated by adversarial inputs, yet few studies evaluate robustness under attack.	[15,24]
Lack of Transparency	Deep learning models (LSTMs, autoencoders) operate as black boxes, reducing trust and limiting actionable insights.	[22,31,46]
Need for Explainability (XAI)	Strong need for interpretable models that justify why a vulnerability was flagged, enabling trust and human oversight.	[5,24,39]

9. Emerging Trends and Future Directions

This section analyzes the emerging trends that are poised to shape the future of AI in cybersecurity, addressing our fourth research question (RQ4). Our analysis identifies a clear shift away from static ML models toward more powerful, context-aware, and adaptive architectures. We provide a deep dive into the most significant trend, large language models (LLMs), followed by an analysis of other key emerging paradigms and a set of concrete future research directions.

Deep dive: the emergence of large language models (LLMs). The most significant trend identified in our review is the rapid application of LLMs to cybersecurity. While earlier models (as seen in Section 5) used traditional ML or basic DL, recent studies are leveraging large, pre-trained transformer models (like BERT, RoBERTa, and GPT) to understand the deep semantic context of both code and natural language. This addresses a core limitation of older models, which lacked this rich, pre-trained understanding.

The reviewed studies apply LLMs to several distinct tasks. The first is as a direct and superior replacement for older text classification models. Ref. [33] introduced ExBERT, a BERT-based transfer learning framework, to perform the nuanced task of predicting a vulnerability's exploitability from its NVD description, achieving 91.12% accuracy. Ref. [45] demonstrated the sheer scalability of these models with VulnBERTa, a RoBERTa-based model trained on NVD data to automate CWE assignment for 160 different CWE classes—a task far beyond the scope of previous ML models that were limited to a few dozen classes [34].

The second and more complex task is direct source code analysis. Ref. [44] used CodeBERT, a model pre-trained specifically on source code, as the foundation for its ProRLearn framework to find vulnerabilities in C/C++ code from datasets like Big-Vul. Ref. [28] similarly proposed a methodology for fine-tuning models like BERT and GPT for detecting web application vulnerabilities, leveraging their pre-trained knowledge to overcome the "limited data availability" that plagued older models.

The third and most transformative application is in semantic reasoning and generation. This is where LLMs move beyond simple classification. Ref. [15] benchmarked models like GPT-3 and T5 on the CISA dataset, not just for detection, but for "semantic search" (i.e., understanding an analyst's query) and generating vulnerability descriptions for unrecorded

(zero-day) vulnerabilities. This generative capability is also the focus of [24], where LLMs were used to analyze C code for buffer overflows and then generate human-readable explanations and the corresponding code fix (e.g., suggesting the replacement of "scanf" with "fgets"). This "closing the loop" from detection to remediation is a key emerging capability.

However, the literature also reveals significant "failure modes," as noted in Section 8. The claims about LLM performance are often "high-level" and lack robustness. The models in [15] (BERT, XLNet) struggled to generate meaningful reports for unrecorded vulnerabilities, performing well only on data similar to their fine-tuning set. This highlights a critical "failure mode": a weakness in generalizing to truly novel threats and a heavy reliance on domain-specific fine-tuning [28]. Furthermore, the "adversarial brittleness" and robustness of these models are rarely tested [24], and their massive computational demands pose a significant barrier to deployment.

Other emerging trends: dynamic and explainable AI: Beyond LLMs, we identified two other significant trends. The first is the shift toward dynamic and adaptive systems using deep reinforcement learning (DRL). Static models can detect threats, but DRL agents can learn optimal policies for responding to them in real-time. This is demonstrated by [16] for dynamic network defense and, most notably, by [23] (Deep VULMAN) for optimizing patch prioritization. The DRL agent learns to manage a budget of resources under the "stochastic" (uncertain) arrival of new vulnerabilities, representing a move from static detection to fully adaptive, autonomous management.

The second trend is the move toward trustworthy and explainable AI (XAI). As discussed in Section 8, the "black box" nature of DL is a major barrier to adoption. In response, frameworks are being developed to make AI systems interpretable. Ref. [5] proposed a "Human-in-the-Loop" (HITL) framework built entirely on XAI to provide transparency. A more integrated approach is neuro-symbolic computing, as seen in LICALITY [39]. By combining a neural network (for pattern matching) with auditable probabilistic logic (for reasoning), this hybrid system can explain why it assigned a certain risk score, building the trust required for critical infrastructure. These emerging trends and their descriptions are summarized in Table 12.

Table 12. Emerging trends in AI for cybersecurity.

Trend	Description	Related Papers
Advanced LLMs	Enhanced code analysis, semantic reasoning, and automated patching.	[24,44]
Security-focused LLMs	Models trained on cybersecurity data for detection, summarization, and generative tasks.	[15,28,45]
Explainable AI (XAI)	Provides transparency in AI decisions to build trust and support analyst oversight.	[5]
Neuro-Symbolic Computing	Combines neural networks with logical reasoning for risk-aware vulnerability prioritization.	[39]
Dynamic Defense (DRL)	Uses deep reinforcement learning for adaptive, real-time threat response and resource management.	[16,23]
AI-driven OSINT Analysis	Applies AI to open-source intelligence to discover corporate exposure and emerging vulnerabilities.	[4]

Future research directions: Based on the critical challenges identified in Section 8 and the promising trends discussed here, we propose several key directions for future research, outlined in Table 13. First, the field must address the data and benchmarking gap. This includes the development of large-scale, standardized, and public benchmark datasets for both code analysis (across multiple languages) and network traffic, enabling true "apples-to-apples" comparison of models. Second, research must focus on robustness

and generalizability. Future work should explicitly test models against adversarial attacks and evaluate their ability to generalize to unseen codebases, languages, and network environments [16,23]. Third, the community should focus on hybrid and explainable models. Instead of pursuing pure "black box" performance, integrating DL with logical reasoning (like neuro-symbolic AI) [39] or ensuring "Human-in-the-Loop" (HITL) oversight [5] appears to be the most promising path toward creating AI systems that are not only accurate but also trustworthy and effective in real-world security operations. Finally, as LLMs mature, research must move beyond high-level claims to rigorous, reproducible benchmarking of their code repair and zero-day detection capabilities.

Table 13. Future directions in AI for cybersecurity.

Direction	Description
Proactive AI Systems	Research into models that can predict and prevent attacks before they occur.
Robustness and Adversarial Testing	A critical need to benchmark AI models against adversarial inputs to ensure reliability under attack.
Standardized Benchmarks	Development of large, public, and modern datasets for true model comparison and reproducibility.
Collaborative Defense (HITL)	Combining human expertise with AI to achieve more reliable, interpretable, and explainable cybersecurity systems.
Ethical and Regulatory Frameworks	Guidelines for the responsible development, deployment, and auditing of security-focused AI systems.
Generalizable Systems	Improving systems to operate effectively across programming languages, platforms, and network environments [22,23].

10. Conclusions

This systematic review has critically evaluated the role of artificial intelligence in vulnerability detection and patch management, synthesizing 29 primary studies. Our findings confirm that AI-driven techniques represent a fundamental paradigm shift, moving the field from the reactive, signature-based methods of the past to a proactive, pattern-based, and predictive future. Our comparative analysis in Section 7 demonstrates that AI models substantially outperform traditional approaches in detection accuracy, scalability, and mitigation speed. We found that AI-driven systems are uniquely capable of addressing core challenges that have long plagued security teams: DL models like LSTMs and autoencoders can identify novel zero-day anomalies, while AI-driven prioritization can intelligently manage the overwhelming scale of modern vulnerability alerts.

However, our synthesis in Section 8 also reveals that the field is nascent and faces significant, systemic challenges. The most critical barrier is the "data-grounding problem": a profound lack of standardized, modern, and representative public datasets for training and benchmarking. This, in turn, fuels the "generalizability problem," as models trained on specific, often-aging datasets (like NVD or SARD) or in simulated environments may not be robust or effective in real-world, production networks. Furthermore, we identified a critical lack of testing for "adversarial robustness" and a major barrier to adoption in the "black-box" nature of many models, which hinders the human trust essential for high-stakes security operations.

To address these gaps, our analysis in Section 9 identified clear and promising trends. The most significant is the emergence of large language models (LLMs), which are moving the field beyond simple classification and toward generative tasks like automated code-fix suggestions and human-readable mitigation reports. To solve the "trust" problem, we identified the rise in Explainable AI (XAI) frameworks, hybrid neuro-symbolic systems that combine learning with logic, and Human-in-the-Loop (HITL) designs. Finally, deep re-

inforcement learning (DRL) is emerging as a powerful paradigm for creating truly dynamic and adaptive defense policies, a crucial step beyond static detection.

Ultimately, this review underscores that the convergence of AI and cybersecurity is not merely a technological shift but an interdisciplinary challenge. Realizing the full potential of AI-driven defenses requires a concerted effort to address the current limitations. Interpretation of the evidence is necessarily shaped by the diversity of tasks, datasets, and evaluation protocols reported in the primary studies; accordingly, quantitative comparisons were restricted to clearly comparable clusters, and conclusions were contextualized using the structured quality appraisal (Supplementary Table S1). Future research must focus on creating robust, standardized benchmarks, testing for adversarial resilience, and building hybrid, explainable models that are not only accurate but also auditable and trustworthy. This requires collaboration between computer scientists, security practitioners, ethicists, and policymakers to foster the development of proactive, adaptive, and responsible AI systems capable of securing the next generation of digital infrastructure.

Supplementary Materials: The following supporting information can be downloaded at: https://www.mdpi.com/article/10.3390/make8010019/s1, Supplementary Table S1: Full quality appraisal (risk-of-bias) scoring matrix for all included studies (n = 29), including rubric definitions (C1–C7), per-study scores, total score, and evidence tier. Supplementary Table S2: Completed PRISMA 2020 checklist (with manuscript locations) [29].

Author Contributions: Conceptualization, M.M. and R.A.; Formal Analysis, M.M. and R.A.; Methodology, M.M. and R.A.; Validation, M.M. and R.A.; Visualization, M.M.; Writing—Original Draft Preparation, M.M.; Writing—Review and Editing, M.M. and R.A.; Project Administration, R.A.; Supervision, R.A. All authors have read and agreed to the published version of the manuscript.

Funding: This research received no external funding.

Institutional Review Board Statement: Not applicable.

Informed Consent Statement: Not applicable.

Data Availability Statement: No new data were created or analyzed in this study. All data used in this systematic review are publicly available in previously published articles, as detailed within the References section.

Conflicts of Interest: The authors declare no conflicts of interest.

Appendix A. Search Strategy Details

Table A1 provides the detailed search strings and additional information used during the database search process:

Table A1. Search strategy details.

Database	Search Strategy
IEEE Xplore	((“Artificial Intelligence” OR “Machine Learning” OR “Deep Learning” OR “Large Language Models” OR “LLMs”) AND (“Cybersecurity” OR “Vulnerability Detection” OR “Patching” OR “Code Analysis”)) AND (Publication Years: 2010–2024)
ACM Digital Library	Title-Abstract:((“Artificial Intelligence” OR “AI” OR “Machine Learning” OR “ML” OR “Deep Learning” OR “Neural Networks” OR “Large Language Models” OR “LLMs” OR “Natural Language Processing” OR “NLP”) AND (“Cybersecurity” OR “ cybersecurity”) AND (“Vulnerability Detection” OR “Vulnerability Management” OR “Vulnerability Mitigation”))

Table A1. *Cont.*

Database	Search Strategy
SpringerLink	(“Artificial Intelligence” OR “AI” OR “Machine Learning” OR “ML” OR “Deep Learning” OR “Neural Networks” OR “Large Language Models” OR “LLMs” OR “Natural Language Processing” OR “NLP”) AND (“Cybersecurity” OR “cybersecurity”) AND (“Vulnerability Detection” OR “Vulnerability Management” OR “Patching” OR “Patch Management” OR “Automated Patching” OR “Patch Prioritization” OR “Vulnerability Mitigation”)
ScienceDirect (Elsevier)	(“Artificial Intelligence” OR “AI” OR “Machine Learning” OR “ML” OR “Deep Learning” OR “Neural Networks” OR “Large Language Models” OR “LLMs” OR “Natural Language Processing” OR “NLP”) AND (“Cybersecurity” OR “cybersecurity”) AND (“Vulnerability Detection” OR “Vulnerability Management” OR “Patching” OR “Patch Management” OR “Automated Patching” OR “Patch Prioritization” OR “Vulnerability Mitigation”)
Scopus	TITLE-ABS-KEY((“Artificial Intelligence” OR “AI” OR “Machine Learning” OR “ML” OR “Deep Learning” OR “Neural Networks” OR “Large Language Models” OR “LLMs” OR “Natural Language Processing” OR “NLP”) AND (“Cybersecurity” OR “cybersecurity”) AND (“Vulnerability Detection” OR “Vulnerability Management” OR “Patching” OR “Patch Management” OR “Automated Patching” OR “Patch Prioritization” OR “Vulnerability Mitigation”)) AND PUBYEAR > 2010
Web of Science	TS = ((‘‘Artificial Intelligence’’ OR ‘‘AI’’ OR ‘‘Machine Learning’’ OR ‘‘ML’’ OR ‘‘Deep Learning’’ OR ‘‘Neural Networks’’ OR ‘‘Large Language Models’’ OR ‘‘LLMs’’ OR ‘‘Natural Language Processing’’ OR ‘‘NLP’’) AND (‘‘Cybersecurity’’ OR ‘‘cybersecurity’’) AND (‘‘Vulnerability Detection’’ OR ‘‘Vulnerability Management’’ OR ‘‘Patching’’ OR ‘‘Patch Management’’ OR ‘‘Automated Patching’’ OR ‘‘Patch Prioritization’’ OR ‘‘Vulnerability Mitigation’’))

Appendix B. Glossary

This glossary provides definitions for key terms and acronyms used throughout this paper, aiming to enhance understanding and clarity.

- AI (Artificial Intelligence): the broad field of computer science focused on developing systems that can perform tasks requiring human intelligence, such as decision-making, pattern recognition, and problem-solving, as applied to cybersecurity defense.
- APT (Advanced Persistent Threat): a type of sophisticated, long-term cyber attack in which malicious actors gain unauthorized access to a network and remain undetected for extended periods.
- AUC (Area Under the Curve): a performance metric, typically referring to the area under the Receiver Operating Characteristic (ROC) curve, used to evaluate the discriminative ability of a binary classifier.
- BERT (Bidirectional Encoder Representations from Transformers): a transformer-based language model pre-trained on large text corpora to capture bidirectional contextual representations, widely used for vulnerability classification and semantic analysis.
- CNN (Convolutional Neural Network): a deep learning model originally designed for image processing and adapted to capture local patterns in sequential data such as vulnerability descriptions and source code tokens.
- CodeBERT: a transformer-based model pre-trained jointly on natural language and source code, enabling semantic understanding of programming constructs for tasks such as vulnerability detection.
- CVE (Common Vulnerabilities and Exposures): a standardized dictionary of publicly disclosed cybersecurity vulnerabilities, each identified by a unique CVE identifier.
- CVSS (Common Vulnerability Scoring System): an open framework for assessing and communicating the severity of software vulnerabilities through standardized numerical scores.

- CWE (Common Weakness Enumeration): a community-developed catalog of common software and hardware weakness types that can lead to vulnerabilities.
- DL (Deep Learning): a subset of machine learning that uses multi-layered artificial neural networks to automatically learn complex, hierarchical feature representations from data.
- DRL (Deep Reinforcement Learning): a class of AI methods that combines deep learning with reinforcement learning, enabling agents to learn adaptive policies through interaction with an environment.
- GPT (Generative Pre-trained Transformer): a family of large language models trained using autoregressive objectives, capable of generating and reasoning over natural language and source code.
- IDS (Intrusion Detection System): a security system that monitors network traffic or system activities to detect malicious behavior or policy violations.
- KNN (k-Nearest Neighbors): a non-parametric machine learning algorithm that classifies instances based on the majority label of their nearest neighbors in feature space.
- LLM (Large Language Model): a large-scale transformer-based model trained on extensive corpora of text and code, capable of advanced language understanding, reasoning, and generation.
- LSTM (Long Short-Term Memory): a type of recurrent neural network designed to model long-range dependencies in sequential data such as network traffic or source code.
- ML (Machine Learning): a subfield of AI focused on developing systems that learn patterns from data without explicit programming, widely used for classification, prediction, and prioritization tasks.
- NLP (Natural Language Processing): a field of AI concerned with enabling computers to understand, analyze, and process human language, applied here to vulnerability reports and security logs.
- NVD (National Vulnerability Database): a U.S. government repository providing standardized vulnerability management data based on the CVE framework.
- OSINT (Open-Source Intelligence): intelligence collected from publicly available sources and analyzed to identify potential security risks or exposures.
- RF (Random Forest): an ensemble machine learning algorithm that constructs multiple decision trees and aggregates their predictions to improve accuracy and robustness.
- RL (Reinforcement Learning): a learning paradigm in which an agent learns optimal actions by interacting with an environment and receiving reward signals.
- RoBERTa (Robustly Optimized BERT Pretraining Approach): an optimized variant of BERT that improves training efficiency and performance through enhanced pretraining strategies.
- RNN (Recurrent Neural Network): a class of neural networks designed for sequential data processing, commonly used for time-series analysis and code representation.
- SVM (Support Vector Machine): a supervised learning algorithm that constructs optimal decision boundaries for classification and regression tasks.
- XAI (Explainable Artificial Intelligence): rechniques and frameworks that make AI model decisions interpretable and understandable to humans, improving trust in security-critical applications.
- Zero-Day Exploit: an exploit that targets a previously unknown vulnerability for which no patch or signature is yet available.

References

1. Atlam, H.F.; Wills, G.B. IoT Security, Privacy, Safety and Ethics. In *Digital Twin Technologies and Smart Cities*; Springer International Publishing: Cham, Switzerland, 2020; pp. 123–149. [CrossRef]
2. Botta, A.; De Donato, W.; Persico, V.; Pescapé, A. Integration of cloud computing and internet of things: A survey. *Future Gener. Comput. Syst.* **2016**, *56*, 684–700. [CrossRef]
3. Conti, M.; Dehghantanha, A.; Franke, K.; Watson, S. Internet of Things security and forensics: Challenges and opportunities. *Future Gener. Comput. Syst.* **2018**, *78*, 544–546. [CrossRef]
4. Bizouarn, K.M.; Abdulnabi, M.; Tan, J. OSINT and AI: A Powerful Combination for Company Vulnerability Detection. In Proceedings of the 2023 IEEE 21st Student Conference on Research and Development (SCOReD), Kuala Lumpur, Malaysia, 13–14 December 2023; IEEE: New York, NY, USA, 2023; pp. 246–250.
5. Nguyen, T.N.; Choo, R. Human-in-the-loop XAI-enabled vulnerability detection, investigation, and mitigation. In Proceedings of the 2021 36th IEEE/ACM International Conference on Automated Software Engineering (ASE), Virtual, 15–19 November 2021; IEEE: New York, NY, USA, 2021; pp. 1210–1212.
6. Cybersecurity Ventures. Cybercrime to Cost the World $10.5 Trillion Annually by 2025. 2020. Available online: https://cybersecurityventures.com/hackerpocalypse-cybercrime-report-2016/(accessed on 5 October 2024).
7. Gartner. Reinventing Cybersecurity with Artificial Intelligence. 2021. Available online: https://www.gartner.com/en/documents/3987117 (accessed on 5 October 2024).
8. Saeed, S.; Suayyid, S.A.; Al-Ghamdi, M.S.; Al-Muhaisen, H.; Almuhaideb, A.M. A Systematic Literature Review on Cyber Threat Intelligence for Organizational Cybersecurity Resilience. *Sensors* **2023**, *23*, 7273. [CrossRef]
9. Williams, M.A.; Barranco, R.C.; Naim, S.M.; Dey, S.; Hossain, M.S.; Akbar, M. A vulnerability analysis and prediction framework. *Comput. Secur.* **2020**, *92*, 101751. [CrossRef]
10. Elbes, M.; Hendawi, S.; AlZu'bi, S.; Kanan, T.; Mughaid, A. Unleashing the full potential of artificial intelligence and machine learning in cybersecurity vulnerability management. In Proceedings of the 2023 International Conference on Information Technology (ICIT), Amman, Jordan, 9–10 August 2023; IEEE: New York, NY, USA, 2023; pp. 276–283.
11. Ban, T.; Takahashi, T.; Ndichu, S.; Inoue, D. Breaking Alert Fatigue: AI-Assisted SIEM Framework for Effective Incident Response. *Appl. Sci.* **2023**, *13*, 6610. [CrossRef]
12. Bilge, L.; Dumitras, T. Before We Knew It: An Empirical Study of Zero-Day Attacks in the Real World. In Proceedings of the 2012 ACM Conference on Computer and Communications Security, Raleigh, NC, USA, 16–18 October 2012; pp. 833–844. [CrossRef]
13. Walkowski, M.; Krakowiak, M.; Oko, J.; Sujecki, S. Distributed analysis tool for vulnerability prioritization in corporate networks. In Proceedings of the 2020 International Conference on Software, Telecommunications and Computer Networks (SoftCOM), Hvar, Croatia, 17–19 September 2020; IEEE: New York, NY, USA, 2020; pp. 1–6.
14. Dissanayake, N.; Jayatilaka, A.; Zahedi, M.; Babar, M.A. Software security patch management—A systematic literature review of challenges, approaches, tools and practices. *Inf. Softw. Technol.* **2022**, *144*, 106771. [CrossRef]
15. Lisha, M.; Agarwal, V.; Kamthania, S.; Vutkur, P.; Chari, M. Benchmarking LLM for Zero-day Vulnerabilities. In Proceedings of the 2024 IEEE International Conference on Electronics, Computing and Communication Technologies (CONECCT), Bangalore, India, 12–14 July 2024; IEEE: New York, NY, USA, 2024; pp. 1–6.
16. Sreenivasappa, B.; Anoop, A.; Naval, P. Deep Reinforcement Learning in Automated Network Vulnerability Detection. In Proceedings of the 2023 International Conference on Recent Advances in Science and Engineering Technology (ICRASET), B.G. Nagara, India, 23–24 November 2023; IEEE: New York, NY, USA, 2023; pp. 1–5.
17. Sohi, S.M.; Seifert, J.P.; Ganji, F. RNNIDS: Enhancing network intrusion detection systems through deep learning. *Comput. Secur.* **2021**, *102*, 102151. [CrossRef]
18. Apruzzese, G.; Colajanni, M.; Ferretti, L.; Guido, A.; Marchetti, M. On the effectiveness of machine and deep learning for cyber security. In Proceedings of the 2018 10th International Conference on Cyber Conflict (CyCon), Tallinn, Estonia, 29 May–1 June 2018; IEEE: New York, NY, USA, 2018; pp. 371–390. [CrossRef]
19. Sarker, I.H.; Kayes, A.S.M.; Badsha, S. Cybersecurity data science: An overview from machine learning perspective. *J. Big Data* **2020**, *7*, 41. [CrossRef]
20. Buczak, A.L.; Guven, E. A survey of data mining and machine learning methods for cyber security intrusion detection. *IEEE Commun. Surv. Tutor.* **2016**, *18*, 1153–1176. [CrossRef]
21. Vishnu, P.; Vinod, P.; Yerima, S.Y. A deep learning approach for classifying vulnerability descriptions using self attention based neural network. *J. Netw. Syst. Manag.* **2022**, *30*, 9. [CrossRef]
22. Li, Z.; Zou, D.; Xu, S.; Chen, Z.; Zhu, Y.; Jin, H. Vuldeelocator: A deep learning-based fine-grained vulnerability detector. *IEEE Trans. Dependable Secur. Comput.* **2021**, *19*, 2821–2837. [CrossRef]
23. Hore, S.; Shah, A.; Bastian, N.D. Deep VULMAN: A deep reinforcement learning-enabled cyber vulnerability management framework. *Expert Syst. Appl.* **2023**, *221*, 119734. [CrossRef]

24. Li, H.; Shan, L. LLM-based Vulnerability Detection. In Proceedings of the 2023 International Conference on Human-Centered Cognitive Systems (HCCS), Cardiff, UK, 16–17 December 2023; pp. 1–4. [CrossRef]
25. Shen, Z.; Chen, S. A Survey of Automatic Software Vulnerability Detection, Program Repair, and Defect Prediction Techniques. *Secur. Commun. Netw.* **2020**, *2020*, 8858010. [CrossRef]
26. Semasaba, A.O.A.; Zheng, W.; Wu, X.; Agyemang, S.A. Literature survey of deep learning-based vulnerability analysis on source code. *IET Softw.* **2020**, *14*, 654–664. [CrossRef]
27. Sllame, A.M.; Tomia, T.E.; Rahuma, R.M. A Holistic Approach for Cyber Security Vulnerability Assessment Based on Open Source Tools: Nikto, Acunitx, ZAP, Nessus and Enhanced with AI-Powered Tool ImmuniWeb. In Proceedings of the 2024 IEEE 4th International Maghreb Meeting of the Conference on Sciences and Techniques of Automatic Control and Computer Engineering (MI-STA), Tripoli, Libya, 19–21 May 2024; IEEE: New York, NY, USA, 2024; pp. 68–75.
28. Nana, S.R.; Bassolé, D.; Guel, D.; Sié, O. Deep Learning and Web Applications Vulnerabilities Detection: An Approach Based on Large Language Models. *Int. J. Adv. Comput. Sci. Appl.* **2024**, *15*, 1391–1399. [CrossRef]
29. Page, M.J.; McKenzie, J.E.; Bossuyt, P.M.; Boutron, I.; Hoffmann, T.C.; Mulrow, C.D.; Shamseer, L.; Tetzlaff, J.M.; Akl, E.A.; Brennan, S.E.; et al. The PRISMA 2020 statement: An updated guideline for reporting systematic reviews. *BMJ* **2021**, *372*, n71. [CrossRef] [PubMed]
30. Moher, D.; Liberati, A.; Tetzlaff, J.; Altman, D.G.; Group, T.P. Preferred Reporting Items for Systematic Reviews and Meta-Analyses: The PRISMA Statement. *PLoS Med.* **2009**, *6*, e1000097. [CrossRef] [PubMed]
31. Pan, Y.; Sun, F.; Teng, Z.; White, J.; Schmidt, D.C.; Staples, J.; Krause, L. Detecting web attacks with end-to-end deep learning. *J. Internet Serv. Appl.* **2019**, *10*, 16. [CrossRef]
32. Russo, E.R.; Di Sorbo, A.; Visaggio, C.A.; Canfora, G. Summarizing vulnerabilities' descriptions to support experts during vulnerability assessment activities. *J. Syst. Softw.* **2019**, *156*, 84–99. [CrossRef]
33. Yin, J.; Tang, M.; Cao, J.; Wang, H. Apply transfer learning to cybersecurity: Predicting exploitability of vulnerabilities by description. *Knowl.-Based Syst.* **2020**, *210*, 106529.
34. Aota, M.; Kanehara, H.; Kubo, M.; Murata, N.; Sun, B.; Takahashi, T. Automation of vulnerability classification from its description using machine learning. In Proceedings of the 2020 IEEE Symposium on Computers and Communications (ISCC), Rennes, France, 7–10 July 2020; IEEE: New York, NY, USA, 2020; pp. 1–7.
35. Syed, R. Cybersecurity vulnerability management: A conceptual ontology and cyber intelligence alert system. *Inf. Manag.* **2020**, *57*, 103334. [CrossRef]
36. Gourisetti, S.N.G.; Mylrea, M.; Patangia, H. Cybersecurity vulnerability mitigation framework through empirical paradigm: Enhanced prioritized gap analysis. *Future Gener. Comput. Syst.* **2020**, *105*, 410–431.
37. Kocaman, Y.; Gönen, S.; Barişkan, M.A.; Karacayilmaz, G.; Yilmaz, E.N. A novel approach to continuous CVE analysis on enterprise operating systems for system vulnerability assessment. *Int. J. Inf. Technol.* **2022**, *14*, 1433–1443. [CrossRef]
38. Shivani, T.; Ramakrishna, H.; Nagashree, N. Vulnerability Management using Machine Learning Techniques. In Proceedings of the 2021 IEEE International Conference on Mobile Networks and Wireless Communications (ICMNWC), Tumkur, India, 3–4 December 2021; IEEE: New York, NY, USA, 2021; pp. 1–4.
39. Zeng, Z.; Yang, Z.; Huang, D.; Chung, C.J. Licality—Likelihood and criticality: Vulnerability risk prioritization through logical reasoning and deep learning. *IEEE Trans. Netw. Serv. Manag.* **2021**, *19*, 1746–1760. [CrossRef]
40. Okutan, A.; Mirakhorli, M. Predicting the severity and exploitability of vulnerability reports using convolutional neural nets. In Proceedings of the 3rd International Workshop on Engineering and Cybersecurity of Critical Systems, Online, 16 May 2022; pp. 1–8.
41. Varela-Vaca, Á.J.; Borrego, D.; Gómez-López, M.T.; Gasca, R.M.; Márquez, A.G. Feature models to boost the vulnerability management process. *J. Syst. Softw.* **2023**, *195*, 111541.
42. Hore, S.; Moomtaheen, F.; Shah, A.; Ou, X. Towards optimal triage and mitigation of context-sensitive cyber vulnerabilities. *IEEE Trans. Dependable Secur. Comput.* **2022**, *20*, 1270–1285. [CrossRef]
43. Alshaya, F.A.; Alqahtani, S.S.; Alsamel, Y.A. VrT: A CWE-Based Vulnerability Report Tagger: Machine Learning Driven Cybersecurity Tool for Vulnerability Classification. In Proceedings of the 2023 IEEE/ACM 1st International Workshop on Software Vulnerability (SVM), Melbourne, Australia, 20 May 2023; IEEE: New York, NY, USA, 2023; pp. 10–13.
44. Ren, Z.; Ju, X.; Chen, X.; Shen, H. ProRLearn: Boosting prompt tuning-based vulnerability detection by reinforcement learning. *Autom. Softw. Eng.* **2024**, *31*, 38.
45. Turtiainen, H.; Costin, A. VulnBERTa: On automating CWE weakness assignment and improving the quality of cybersecurity CVE vulnerabilities through ML/NLP. In Proceedings of the 2024 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), Vienna, Austria, 8–12 July 2024; IEEE: New York, NY, USA, 2024; pp. 618–625.
46. Arun, A.; Nair, A.S.; Sreedevi, A. Zero Day Attack Detection and Simulation through Deep Learning Techniques. In Proceedings of the 2024 14th International Conference on Cloud Computing, Data Science & Engineering (Confluence), Noida, India, 18–19 January 2024; IEEE: New York, NY, USA, 2024; pp. 852–857.

47. Hu, Z.; Beuran, R.; Tan, Y. Automated penetration testing using deep reinforcement learning. In Proceedings of the 2020 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), Genoa, Italy, 7–11 September 2020; IEEE: New York, NY, USA, 2020; pp. 2–10.
48. Ge, Y.; Zhu, Q. MEGA-PT: A Meta-game Framework for Agile Penetration Testing. In Proceedings of the International Conference on Decision and Game Theory for Security, New York, NY, USA, 16–18 October 2024; Sinha, A., Fu, J., Zhu, Q., Zhang, T., Eds.; Springer Nature: Cham, Switzerland, pp. 24–44.
49. Charoenwet, W.; Thongtanunam, P.; Pham, V.T.; Treude, C. Toward effective secure code reviews: An empirical study of security-related coding weaknesses. *Empir. Softw. Eng.* **2024**, *29*, 88. [CrossRef]
50. Yu, J.; Fu, L.; Liang, P.; Tahir, A.; Shahin, M. Security defect detection via code review: A study of the openstack and qt communities. In Proceedings of the 2023 ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM), New Orleans, LA, USA, 26–27 October 2023; IEEE: New York, NY, USA, 2023; pp. 1–12.
51. Braz, L.; Aeberhard, C.; Çalikli, G.; Bacchelli, A. Less is More: Supporting Developers in Vulnerability Detection during Code Review. In Proceedings of the 2022 IEEE/ACM 44th International Conference on Software Engineering (ICSE), Pittsburgh, PA, USA, 21–29 May 2022; IEEE: New York, NY, USA, 2022.
52. Shah, S.; Mehtre, B.M. An overview of vulnerability assessment and penetration testing techniques. *J. Comput. Virol. Hacking Tech.* **2015**, *11*, 27–49. [CrossRef]
53. Al-Sinani, H.S.; Mitchell, C.J. AI-Augmented Ethical Hacking: A Practical Examination of Manual Exploitation and Privilege Escalation in Linux Environments. *arXiv* **2024**, arXiv:2411.17539. [CrossRef]
54. Uddin, M.; Rahman, A.A. Dynamic Multi Layer Signature based Intrusion Detection system Using Mobile Agents. *arXiv* **2010**, arXiv:1010.5036. [CrossRef]
55. Aldwairi, M.; Flaifel, Y.; Mhaidat, K. Efficient Wu-Manber Pattern Matching Hardware for Intrusion and Malware Detection. *arXiv* **2020**, arXiv:2003.00405. [CrossRef]
56. Yang, Y.; Peng, X. BERT-based network for intrusion detection system. *EURASIP J. Inf. Secur.* **2025**, *2025*, 11. [CrossRef]
57. Dissanayake, N.; Zahedi, M.; Jayatilaka, A.; Babar, M.A. Why, How and Where of Delays in Software Security Patch Management: An Empirical Investigation in the Healthcare Sector. *Proc. ACM-Hum.-Comput. Interact.* **2022**, *6*, 1–29. [CrossRef]
58. Petrović, G.; Ivanković, M.; Fraser, G.; Just, R. Practical Mutation Testing at Scale. *arXiv* **2021**, arXiv:2102.11378. [CrossRef]
59. Salem, A.H.; Azzam, S.M.; Emam, O.E.; Abohany, A.A. Advancing cybersecurity: A comprehensive review of AI-driven detection techniques. *J. Big Data* **2024**, *11*, 105. [CrossRef]

Disclaimer/Publisher's Note: The statements, opinions and data contained in all publications are solely those of the individual author(s) and contributor(s) and not of MDPI and/or the editor(s). MDPI and/or the editor(s) disclaim responsibility for any injury to people or property resulting from any ideas, methods, instructions or products referred to in the content.